Author: Andrey Pautov. Published on Medium

AI in Offensive Operations: How Threat Actors Use Artificial Intelligence

A CTI assessment of documented malicious and dual-use AI activity through April 12, 2026, with a 2019-2025 comparison and forward forecast.

By Andrey Pautov — Revised April 2026

> *Published on Medium: AI in Offensive Operations: How Threat Actors Use Artificial Intelligence*
>
> *Evidence cutoff: April 12, 2026. Year-over-year comparison tables run through full-year 2025. 2026 is treated separately as a partial-year update.*

Confidence Scale

This report uses an intelligence probability yardstick rather than generic HIGH/MEDIUM/LOW labels:

- **Almost certain** — the judgment is strongly supported and residual uncertainty is limited
- **Highly likely** — the judgment is strongly favored, though not certain
- **Likely / Probable** — the evidence favors the judgment, but plausible alternatives remain
- **Realistic possibility** — the judgment is credible, but the evidence is mixed or incomplete
- **Unlikely** — the evidence weighs against the judgment
- **Highly unlikely** — the evidence strongly weighs against the judgment
- **Remote chance** — the judgment cannot be excluded, but little evidence supports it

The purpose is disciplined expression of uncertainty, not false numerical precision.

Table of Contents

1. Executive Summary
2. Key Judgments
3. Methodology and Assessment Limitations
4. Chronological Timeline
5. Major Incidents and High-Signal Cases
6. Technical Analysis (MITRE ATLAS-Aligned)
7. Adversary Use of Agentic AI
8. Statistics and Measurable Trends
9. Reality vs. Hype
10. Actor Segmentation
11. Supply Chain & Infrastructure
12. Technical Evolution (Last 24 Months)
13. Forecast (Post-April 2026)
14. Final Conclusions
15. Defender Recommendations
16. Key Selected Sources

Introduction

Artificial intelligence is now discussed in cyber threat reporting with two recurring distortions: speculative overstatement on one side, and narrow focus on "AI hacking" as a standalone phenomenon on the other. Both views are analytically weak. Offensive use of AI does not begin with fully autonomous intrusion, and it does not need to. The more useful question is where AI is already changing attacker economics, operational tempo, deception quality, infrastructure choices, and defender exposure.

This report addresses that question by separating three problem sets that are often conflated: **documented malicious use of AI by threat actors**, **defensive or academic research that signals future offensive capability**, and **security risks created by enterprise deployment of AI-enabled applications and agents**. It treats these as related but distinct analytical categories. That distinction matters because a deepfake-enabled fraud case, an LLM prompt-injection weakness in an enterprise assistant, a provider disclosure of agentic

misuse, and a research paper on one-day exploitation do not carry the same evidentiary weight or operational meaning.

This revision updates the historical record through **April 12, 2026**. That change is methodological, not rhetorical: the public evidence base is materially different after 2025. The comparison section therefore separates a full-year **2019-2025** trend view from a **2026 year-to-date** update. By contrast, the defensive sections use current MITRE ATLAS and OWASP 2025 terminology because defenders need a modern control framework even when some of the referenced incidents predate that taxonomy.

The intended audience is CTI analysts, security architects, detection engineers, and technical decision-makers who need a source-disciplined view of what is actually known, what is merely plausible, and where enterprise controls should adapt first. The central judgment is now sharper than it was in 2024: **2025 marked the public inflection point**, but the strongest pattern through April 2026 is still not general-purpose autonomous hacking. It is the convergence of AI-enhanced fraud, AI-accelerated intrusion support, agentic misuse with bounded human oversight, and rapid expansion of the enterprise AI stack as an attack surface.

---

1. Executive Summary

Through April 12, 2026, the public record shows a clear transition from **AI as attacker productivity support** to **AI as an operational component in selected parts of real campaigns**. The transition is real, but uneven. The dominant effect is still acceleration and scaling of existing tradecraft, not wholesale replacement of skilled operators across the full intrusion lifecycle.

The historical pattern is now best understood in five layers:

1. **Fraud and impersonation:** March 2019 voice-cloning fraud in the UK, the 2020 UAE deep-voice case, the February 2024 Hong Kong reported video-conference fraud, and 2025 FBI warnings on AI-generated voice impersonation show that synthetic media remains the earliest and most financially mature criminal AI use case.
2. **Phishing and social engineering:** By 2024-2026, AI had become a routine force multiplier for multilingual lure generation, role-tailored phishing, identity fabrication, and high-volume messaging. Microsoft's April 6, 2026 device-code-phishing research shows AI improving speed, personalization, and timing precision rather than changing the underlying credential-theft logic.
3. **State-linked and criminal augmentation:** OpenAI, Google GTIG, Microsoft, and Anthropic collectively documented threat actors using LLMs and agentic tools for reconnaissance, vulnerability research, translation, phishing, malware debugging, post-compromise support, and data triage.

4. **Operational integration in 2025:** Google GTIG documented PROMPTSTEAL, PROMPTFLUX, and QUIETVAULT in November 2025, showing public evidence of malware that queries or leverages models during execution, self-modifies with LLM support, or abuses local AI tooling on victim hosts.
5. **AI stack exposure:** Prompt injection, excessive agency, AI API token theft, AI-service misuse, and AI-adjacent supply chain compromise now form a confirmed defensive problem set. The March 2026 LiteLLM compromise is a high-signal example of AI infrastructure itself becoming a target.

Two analytical conclusions follow.

First, **2025 is the strongest public inflection point** in the AI threat timeline. It is the year in which the record expands from phishing, fraud, and coding assistance into LLM-integrated malware, AI-service API misuse as an operational channel, and provider-reported high-autonomy agentic misuse.

Second, **the strongest near-term enterprise risk still sits outside "autonomous hacking" hype**. The highest-confidence harms remain AI-enhanced phishing, vishing, impersonation fraud, identity abuse, prompt injection, unsafe tool-calling, and theft or misuse of AI credentials and connectors. Even the most aggressive 2025 provider disclosures still show hallucination, operator oversight, or single-source concentration as important constraints.

The most important 2026 update is not that AI has replaced human intruders. It is that threat actors now treat AI simultaneously as a **tool**, a **traffic path**, a **credential surface**, and an **enterprise attack surface**.

---

2. Key Judgments

KJ-1 [Likely] — The March 2019 UK voice-cloning fraud remains the earliest publicly documented criminal AI-enabled case identified in the open reporting reviewed for this document. Earlier cases may exist in restricted reporting or were not explicitly identified as AI-enabled at the time.

KJ-2 [Almost certain] — Across 2019-2026, the primary operational value of AI to threat actors is capability uplift in social engineering, reconnaissance, translation, scripting, identity fraud, and post-compromise support functions.

KJ-3 [Highly likely] — 2025 was the public inflection point in the AI threat record. By late 2025, official and provider reporting included LLM-integrated malware, AI-service API misuse, and high-autonomy agentic support for extortion and espionage.

KJ-4 [Highly likely] — Even after that 2025 shift, the strongest pattern remains AI augmentation of existing TTPs rather than replacement of the full attack chain with autonomous AI.

KJ-5 [Likely] — Provider disclosures in August and November 2025 show that agentic AI misuse is no longer purely theoretical. However, these cases remain partly constrained by single-source reporting, uneven independent corroboration, and persistent human oversight.

KJ-6 [Highly likely] — Fully autonomous, end-to-end advanced intrusion at operational scale remained unproven in the open record through April 12, 2026. The most aggressive public claims still show hallucination, human checkpoints, or both.

KJ-7 [Almost certain] — The highest near-term enterprise risk remains AI-enabled impersonation fraud, phishing, identity abuse, and AI-assisted credential theft, especially where approval processes still trust voice, video, or polished written language.

KJ-8 [Almost certain] — The enterprise AI stack is now a confirmed attack surface. Prompt injection, excessive agency, unsafe tool invocation, AI API token theft, AI-service misuse, and AI-adjacent supply chain compromise are no longer merely design concerns.

KJ-9 [Likely] — Most 2023 underground "dark LLM" offerings were wrappers, repackaging, or marketing claims rather than independently validated purpose-built criminal models. By 2025, however, underground AI tooling and repurposed mainstream/agentic services had matured enough to lower barriers for lower-skill actors in fraud, phishing, and malware development.

KJ-10 [Likely] — Official quantification is now emerging. The FBI's 2025 IC3 annual report introduced an AI-related descriptor and recorded **22,364 complaints** and **$893,346,472** in losses, reinforcing that the dominant measurable impact remains in cyber-enabled fraud and impersonation rather than high-end autonomous intrusion.

---

3. Methodology and Assessment Limitations

This assessment uses publicly available material only. Historical findings are bounded to documents and reporting available through **April 12, 2026**.

a) Scope discipline. Historical incidents, actor cases, and technical claims dated after April 12, 2026 are excluded from the evidentiary record. The comparison tables run through full-year 2025; 2026 is treated separately as a partial-year update to avoid false precision.

b) Public reporting bias. Open reporting disproportionately captures cases that are unusual, embarrassing, commercially useful to disclose, or detectable by platform providers. The absence of public reporting is not evidence of capability absence.

c) Provider-selection bias. OpenAI, Microsoft, Google, and other platform operators can only report what they can observe on their own systems. Their reporting is valuable, but it reveals observed abuse of their platforms, not the full population of malicious AI use.

d) Source quality variation. This report distinguishes among primary government disclosures, provider telemetry, academic preprints, vendor research, and media reporting with primary-document basis. Secondary sources are used only where primary records are unavailable or inaccessible.

e) Comparison-method note. The statistical comparison in Section 8 uses three author-coded measures: `(1)` official/provider disclosures in scope, `(2)` documented AI-relevant attack-surface classes, and `(3)` AI-improved TTP families. These are indicators of visibility and diversification inside this report's corpus, not census-quality counts of all global activity.

f) Single-source concentration. Some of the most consequential 2025 disclosures, especially Anthropic's August and November 2025 casework, originate from a single provider. They are analytically important but require explicit caution when used to infer broader prevalence.

g) Technical framework note. Historical behavior is bounded to the 2026 cutoff, but the technical analysis and defensive strategy use current MITRE ATLAS AML identifiers and OWASP Top 10 for LLMs and GenAI 2025 terminology. These frameworks are used as normalization layers, not as evidence that adversaries or defenders described events that way at the time.

h) ATT&CK usage. MITRE ATT&CK is retained only where conventional cyber context materially clarifies the enterprise impact. MITRE ATLAS remains the lead framework for AI-enabled techniques.

i) Forecast method. The forecast section projects forward from the April 12, 2026 baseline using public reporting, research signals, and observed attacker incentives. It is not retrospective evidence.

---

4. Chronological Timeline

> ***Legend:*** *CONFIRMED = primary source or direct official disclosure. REPORTED = credible secondary reporting with a primary-document basis. RESEARCH = academic or vendor research signal, not in-the-wild malicious deployment.*

2019

March 2019 — UK voice-cloning fraud

Actor: Unknown criminal operators | *Evidence:* REPORTED

Criminals used AI-generated voice impersonation in a CEO fraud / BEC-style scheme and induced a transfer of EUR220,000.

Why it matters: Earliest public open-source case in this review of generative-AI-enabled fraud.

2020

January 2020 (publicly reported October 2021) — UAE bank deep-voice fraud

Actor: Unknown criminal group | *Evidence:* REPORTED

Court-document-based reporting described the use of "deep voice" impersonation alongside forged emails in a fraud totaling roughly USD35 million.

Why it matters: Demonstrated scale and cross-border coordination far beyond the 2019 case.

2021

August 2021 — GPT-3 phishing benchmark in government research

Actor: Defensive research | *Evidence:* RESEARCH

Singapore government researchers presented evidence that GPT-3-generated phishing emails could outperform or match human-crafted phishing in controlled conditions.

Why it matters: Early high-signal proof that LLMs could compress phishing labor and improve social-engineering quality before mass-market LLM access.

2022

May 2022 — U.S. advisory on DPRK IT workers

Actor: DPRK-linked labor and revenue-generation ecosystem | *Evidence:* CONFIRMED

The U.S. Department of State, Treasury, and FBI warned that DPRK IT workers were using false personas, stolen identities, and obfuscation to obtain remote technical work.

Why it matters: Not an AI case by itself, but important context for later AI-assisted identity fraud concerns.

November 2022 — ChatGPT public release

Actor: Global enabling event | *Evidence:* CONFIRMED

OpenAI publicly released ChatGPT, making capable conversational LLM access mass-market.

Why it matters: Democratization event, not an attack event; it materially lowered access barriers for phishing, fraud scripting, and translation support.

2023

August 2023 — Trend Micro assesses WormGPT / FraudGPT claims

Actor: Underground vendors and resellers | *Evidence:* RESEARCH

Trend Micro found clear underground interest and marketing activity around WormGPT and FraudGPT, but limited proof that the advertised "criminal LLM" products had the capabilities claimed.

Why it matters: Important corrective against inflated reporting on bespoke criminal AI models.

October 2023 — IBM X-Force phishing benchmark

Actor: Defensive research | *Evidence:* RESEARCH

IBM showed that a generative-AI-assisted phishing workflow could produce persuasive phishing emails in minutes rather than many hours.

Why it matters: Useful empirical signal for attacker productivity gains.

Late 2023 — AI-assisted identity and employment fraud becomes clearer in DPRK-linked activity

Actor: DPRK-linked IT worker ecosystem | *Evidence:* CONFIRMED

Later official and provider reporting tied AI-generated identities, resume support, and language assistance to DPRK remote-worker fraud operations already active in 2023.

Why it matters: Expanded the AI threat picture from short-duration scams to persistent access and long-duration fraud operations.

2024

January 24, 2024 — NCSC publishes near-term AI cyber threat assessment

Actor: UK government | *Evidence:* CONFIRMED

NCSC assessed that AI would almost certainly increase the volume and impact of cyber attacks and that the near-term threat would come mainly from evolution of existing TTPs.

Why it matters: Baseline government assessment, methodologically rigorous and explicit on uncertainty.

February 7, 2024 — Hong Kong police case summarized by HKCERT

Actor: Unknown criminal operators | *Evidence:* REPORTED

Hong Kong police statements, as summarized by HKCERT and reported in the media, described a deepfake-enabled video-conference fraud that induced transfers totaling HKD200 million to five accounts.

Why it matters: Strong early-2024 public evidence of escalation from audio-only impersonation to multi-person video deception, but the open-source chain is still indirect rather than a direct victim disclosure.

February 14, 2024 — OpenAI and Microsoft disclose five state-affiliated actors using LLMs

Actor: Forest Blizzard, Emerald Sleet, Crimson Sandstorm, Charcoal Typhoon, Salmon Typhoon | *Evidence:* CONFIRMED

Reported use included open-source research, translation, scripting support, debugging, and phishing content generation.

Why it matters: First major public provider-backed disclosure tying named state-affiliated actors to LLM usage.

April 11-17, 2024 — UIUC publishes one-day vulnerability exploitation results

Actor: Academic research | *Evidence:* RESEARCH

UIUC researchers reported that GPT-4 could exploit 87% of a 15-vulnerability one-day benchmark when given the CVE description, but only 7% without it.

Why it matters: Strong research signal that advanced models can materially assist post-disclosure exploitation, but not evidence of operational deployment.

April 11, 2024 — Microsoft details prompt-injection and guardrail-bypass risks

Actor: Microsoft security research | *Evidence:* CONFIRMED

Microsoft documented direct prompt injection, indirect prompt injection via poisoned content, and multi-turn jailbreak patterns against AI-integrated applications.

Why it matters: Marked the transition from "AI used by attackers" to "AI systems themselves as attack surface."

May 30, 2024 — OpenAI details covert influence operations using its models

Actor: Multiple IO networks | *Evidence:* CONFIRMED

OpenAI disclosed multiple covert influence operations using its models for content generation, translation, research, and basic automation support.

Why it matters: Reinforced the pattern that AI was improving scale and efficiency in influence operations without yet proving decisive audience impact.

November 13, 2024 — FinCEN warns on deepfake fraud targeting financial institutions

Actor: U.S. Treasury / FinCEN | *Evidence:* CONFIRMED

FinCEN documented deepfake-enabled fraud as an emerging financial-sector risk.
Why it matters: Marked regulatory acknowledgement that synthetic audio and video had become financially material threats.

2025

January 29, 2025 — Google GTIG publishes "Adversarial Misuse of Generative AI"
Actor: Multiple APT and IO actors | *Evidence:* CONFIRMED
Google assessed that Gemini misuse involved APT groups from more than 20 countries and spanned reconnaissance, vulnerability research, scripting, phishing content, and post-compromise support.
Why it matters: First broad provider-backed mapping of state-linked AI use across much of the attack lifecycle.

February 21, 2025 — OpenAI updates malicious-use reporting
Actor: Multiple networks | *Evidence:* CONFIRMED
OpenAI's February 2025 report continued the pattern of AI abuse across scams, covert influence, and malicious cyber support activity.
Why it matters: Showed that malicious AI use was diversifying operationally, even where novel capability gains remained limited.

May 15, 2025 — FBI warns on impersonation of senior U.S. officials
Actor: Unknown criminal and influence actors | *Evidence:* CONFIRMED
FBI reporting documented malicious messaging and impersonation campaigns targeting senior U.S. officials and their contacts.
Why it matters: Elevated AI-enabled impersonation from enterprise fraud risk to a national-level trust and access problem.

June 5, 2025 — OpenAI publishes June 2025 misuse report
Actor: Multiple networks | *Evidence:* CONFIRMED
OpenAI reported detection of abusive activity including cyber espionage, social engineering, deceptive employment schemes, covert influence operations, and scams.
Why it matters: Confirmed that AI misuse was becoming a repeat reporting stream rather than isolated casework.

August 27, 2025 — Anthropic reports Claude Code misuse in large-scale extortion
Actor: Criminal actor; additional DPRK-linked fraud casework | *Evidence:* CONFIRMED
Anthropic reported Claude Code supporting a data-extortion operation against at least 17 organizations and

described broader misuse including DPRK employment fraud and AI-generated ransomware sales.
Why it matters: One of the clearest public signals that agentic coding systems had moved from experimentation into offensive support roles.

October 7, 2025 — OpenAI reports more than 40 disrupted malicious networks since February 2024
Actor: Multiple networks | *Evidence:* CONFIRMED
OpenAI stated that it had disrupted and reported over 40 networks violating its policies since public threat reporting began.
Why it matters: Demonstrated sustained reporting volume and recurring multi-domain misuse of mainstream AI systems.

November 3, 2025 — Microsoft documents SesameOp
Actor: Unknown threat actor | *Evidence:* CONFIRMED
Microsoft incident responders documented a backdoor using the OpenAI Assistants API for command-and-control communications.
Why it matters: First high-signal public case of a commercial AI API being used as an operational relay channel.

November 5, 2025 — Google GTIG AI Threat Tracker identifies operational AI-enabled malware
Actor: Multiple state-linked and criminal actors | *Evidence:* CONFIRMED
GTIG documented PROMPTSTEAL, PROMPTFLUX, QUIETVAULT, and other malware families using AI during execution, for self-rewriting, or through on-host AI tooling.
Why it matters: Strongest public evidence that AI was no longer limited to coding assistance and phishing text generation.

November 13, 2025 — Anthropic reports AI-orchestrated espionage case
Actor: Chinese state-sponsored actor, per Anthropic assessment | *Evidence:* CONFIRMED
Anthropic reported an espionage campaign in which Claude Code allegedly performed 80-90% of campaign actions across roughly 30 targets, with limited human intervention.
Why it matters: Most aggressive public provider claim to date on high-autonomy agentic intrusion, though still subject to single-source caution.

December 19, 2025 — FBI updates warning on senior U.S. official impersonation
Actor: Unknown actors | *Evidence:* CONFIRMED
FBI stated malicious actors had been impersonating senior U.S. officials in text and AI-generated voice campaigns since at least 2023.
Why it matters: Officially linked AI-generated voice impersonation to sustained targeting of senior officials and their networks.

2026

February 25, 2026 — OpenAI publishes 2026 malicious-use report

Actor: Multiple networks | *Evidence:* CONFIRMED

OpenAI emphasized that threat actors often combine AI with websites, social platforms, and multiple models rather than relying on a single AI service.

Why it matters: Reinforced that multi-model workflows and cross-platform misuse had become a normal analytic assumption.

March 6, 2026 — Microsoft publishes "AI as tradecraft"

Actor: Multiple threat actors | *Evidence:* CONFIRMED

Microsoft assessed that threat actors were operationalizing AI across reconnaissance, phishing, malware support, post-compromise analysis, and identity fraud while humans retained control over objectives and deployment decisions.

Why it matters: Strong 2026 articulation of the "AI as accelerator, not replacement" pattern.

March 24, 2026 — TeamPCP compromises LiteLLM

Actor: TeamPCP | *Evidence:* CONFIRMED

Wiz documented a supply-chain compromise affecting LiteLLM, demonstrating that AI middleware and proxy infrastructure had become a target in its own right.

Why it matters: Marks AI infrastructure, not just AI use, as a meaningful attack surface.

April 6, 2026 — Microsoft details AI-enabled device code phishing

Actor: Unknown threat actor cluster | *Evidence:* CONFIRMED

Microsoft described a widespread device-code-phishing campaign that used AI-generated lures, dynamic code generation, automated backend infrastructure, and rapid post-compromise enrichment.

Why it matters: Illustrates the 2026 state of play: AI meaningfully sharpens existing phishing tradecraft without changing its core logic.

---

5. Major Incidents and High-Signal Cases

5.1 UK Energy-Sector Voice-Cloning Fraud

Date: March 2019

Actor: Unknown criminal operators

Victim profile: UK subsidiary executive at an energy company

AI component: Synthetic voice impersonation of the German parent-company executive

Loss: EUR220,000

Source quality: SECONDARY (Wall Street Journal reporting, based on insurer statements)

Assessment: The payment-authority fraud pattern was not new; the synthetic-voice layer was. The case is best treated as the earliest open-source marker of AI-enabled executive impersonation in financial fraud.

5.2 UAE Deep-Voice Fraud

Date of incident: January 2020

Public reporting: October 2021

Actor: Unknown; UAE reporting referenced at least 17 participants

Victim profile: Bank manager handling funds for a Japanese company

AI component: Voice cloning combined with forged email corroboration

Loss: Approximately USD35 million

Source quality: REPORTED (Forbes reporting based on court documents)

Assessment: The technical novelty lay in the synthetic voice, not the fraud mechanics. What changed materially was scale.

5.3 Hong Kong Deepfake Video-Conference Fraud

Date: Public warning on February 7, 2024

Actor: Unknown criminal operators

Victim profile: Finance staff at a multinational company in Hong Kong

AI component: Deepfake video and voice impersonation of senior executives in a conference setting

Loss: HKD200 million

Source quality: REPORTED (official HKCERT bulletin summarizing police and media reporting)

Assessment: This is one of the strongest public early-2024 cases suggesting that multi-person synthetic video can materially degrade legacy approval controls based on "familiar face plus familiar voice." The victim identity was tied publicly to Arup later, but the February 2024 warning itself still rests on an indirect reporting chain rather than a direct victim disclosure.

5.4 OpenAI / Microsoft State-Actor Disclosure

Date: February 14, 2024
Actors: Forest Blizzard, Emerald Sleet, Crimson Sandstorm, Charcoal Typhoon, Salmon Typhoon
AI component: Open-source research, translation, scripting help, code debugging, and phishing content support
Source quality: CONFIRMED PRIMARY
Assessment: The key finding is not that states are using AI at all, which was predictable, but that the disclosed uses remained narrow and augmentative. Through this date, provider telemetry did not show a public break into autonomous AI-driven intrusion.

5.5 Prompt Injection as an Enterprise Security Problem

Date: April 11, 2024
Actor: Defensive research / anticipated adversary tradecraft
AI component: Direct prompt injection, indirect prompt injection through poisoned content, and multi-turn guardrail bypass
Source quality: CONFIRMED PRIMARY (Microsoft security research)
Assessment: This is not a named threat-actor case. It is included because it defines the most consequential AI-specific attack surface visible by the evidence cutoff: exploitation of LLM-enabled applications through prompt-channel abuse rather than traditional memory corruption.

5.6 UIUC One-Day Exploitation Results

Date: April 11-17, 2024
Actor: Academic research
AI component: GPT-4 agent exploiting one-day vulnerabilities from CVE descriptions
Source quality: RESEARCH (arXiv preprint)
Assessment: This is a high-signal research result. It should inform forecasting, but it should not be misreported as evidence that threat actors were already conducting autonomous AI-led exploitation at comparable reliability.

5.7 PROMPTSTEAL / PROMPTFLUX / QUIETVAULT

Date: Publicly reported November 5, 2025

Actors: Multiple; PROMPTSTEAL linked by Google GTIG to APT28 activity reported by CERT-UA as LAMEHUG

AI component: Runtime LLM command generation, LLM-assisted self-rewriting for evasion, and abuse of on-host AI tooling

Source quality: CONFIRMED PRIMARY (Google GTIG; CERT-UA for LAMEHUG)

Assessment: This is one of the clearest public inflection points in the AI threat record. By late 2025, the record includes malware that calls an LLM during execution, uses an LLM to rewrite itself, or abuses AI tools already present on compromised systems. The operational maturity varies by family, but the shift in design pattern is real.

5.8 Claude Code in Data Extortion

Date: August 27, 2025

Actor: Unnamed criminal actor; Anthropic reporting also includes DPRK-linked fraud activity

AI component: Claude Code used to assist reconnaissance, credential harvesting, intrusion support, data triage, and tailored extortion decision-making

Source quality: CONFIRMED PRIMARY, SINGLE-SOURCE (Anthropic)

Assessment: Anthropic's August 2025 report is the strongest public provider disclosure of agentic AI supporting extortion operations at scale. The case is analytically significant, but it remains provider-sourced and should not be generalized into a claim that such operations were already widespread across the ecosystem.

5.9 SesameOp and AI-Service API Abuse

Date: November 3, 2025

Actor: Unknown threat actor

AI component: Abuse of the OpenAI Assistants API for command-and-control communications

Source quality: CONFIRMED PRIMARY (Microsoft incident response)

Assessment: SesameOp matters less because it is technically complex than because it reframes AI services as blend-in operational infrastructure. It validates the concern that sanctioned model traffic can become a relay path if egress governance is weak.

5.10 Anthropic's AI-Orchestrated Espionage Disclosure

Date: November 13, 2025
Actor: Chinese state-sponsored actor, according to Anthropic's assessment
AI component: Claude Code reported to execute most campaign actions with limited human decision points
Source quality: CONFIRMED PRIMARY, SINGLE-SOURCE (Anthropic)
Assessment: This is the strongest public claim of high-autonomy offensive AI activity in the open record through April 2026. It cannot be ignored, but it should be handled with caution. The case is still provider-originated, and the most defensible interpretation is **substantial AI orchestration with human supervision**, not proof that fully autonomous intrusion had become routine. Notably, through April 2026 no independent government disclosure, victim organization confirmation, or second-provider corroboration has validated this specific case — that absence is itself an analytically relevant data point when estimating prevalence or generalizability.

5.11 LiteLLM and the AI Middleware Supply Chain

Date: March 24, 2026
Actor: TeamPCP
AI component: Not offensive AI use by the actor, but compromise of AI middleware used to broker model access
Source quality: CONFIRMED PRIMARY (Wiz); corroborated by additional vendor and project reporting
Assessment: LiteLLM is included because by 2026 the AI threat story is no longer only about how attackers use models. It is also about how attackers target the packages, proxies, tokens, connectors, and orchestration layers that make enterprise AI systems work.

---

6. Technical Analysis (MITRE ATLAS-Aligned)

> ***Framework note:*** *MITRE ATLAS is the primary technical framework in this section. ATT&CK is referenced only where it still adds conventional enterprise cyber context. Some ATLAS techniques and mitigations cited below were formalized after some of the incidents discussed here; they are used as a current taxonomy, not as evidence that the historical events were labeled this way at the time.*

6.1 Observed and Assessed AI-Enabled Activity Through April 2026

AML.TA0002 — Reconnaissance

Status: CONFIRMED
Observed use: LLM-assisted OSINT, summarization, translation, and target profiling
Examples: Forest Blizzard, Emerald Sleet, Salmon Typhoon, Crimson Sandstorm, multiple 2025-2026 Microsoft and Google case studies
Assessment: AI improves research speed, language coverage, and target familiarization. It does not, by itself, grant access to non-public data.

AML.T0016.002 — Generative AI

Status: CONFIRMED
Observed use: Use of mainstream generative models to draft phishing lures, refine pretexts, accelerate translation, support lightweight coding tasks, and tailor impersonation content
Assessment: Through April 2026, the dominant pattern is still misuse of legitimate mainstream or hosted models rather than deployment of a mature ecosystem of bespoke criminal models.

AML.TA0004 / AML.T0052 — Initial Access / Phishing

Status: CONFIRMED
Observed use: AI-improved phishing, multilingual lure production, executive impersonation support, and device-code-phishing enrichment
Assessment: This remains the clearest public operational uplift area. Synthetic voice and video fraud sit adjacent to phishing in the same deception family even when the end goal is payment fraud rather than network access.

AML.TA0008 / AML.TA0009 / AML.T0036 — Discovery / Collection / Data from Information Repositories

Status: CONFIRMED, WITH CAVEATS
Observed use: Faster review of target-relevant material, post-compromise discovery support, data triage, exfiltration planning, and repository access through connected tools
Assessment: By late 2025, provider casework moved this category from plausible to publicly documented. The strongest examples remain provider-sourced and unevenly corroborated, but the pattern is no longer hypothetical.

AML.T0040 / AML.T0024 — AI Model Inference API Access / Exfiltration via AI Inference API

Status: CONFIRMED

Observed use: Legitimate external model access, exposed provider keys, sensitive-context transmission, and use of AI APIs inside attacker workflows

Assessment: The inference path is now part of the operational perimeter. It is simultaneously a productivity channel, a credential surface, and a potential data-exposure path.

AML.T0096 — AI Service API

Status: CONFIRMED

Observed use: Use of AI-service APIs as operational infrastructure, including relay or control functions

Assessment: SesameOp moved this from forecast into public evidence. AI service traffic must now be treated as a governed egress channel rather than automatically trusted SaaS traffic.

6.2 Prompt Injection and LLM-Mediated Application Abuse

AML.T0051 — LLM Prompt Injection

Historical status through April 2026: CONFIRMED as a vulnerability class and active enterprise attack surface

Prompt injection is the most important AI-native application risk visible in the public record. It includes direct prompt injection by a user, indirect prompt injection via poisoned documents or webpages, and multi-turn jailbreak patterns that progressively steer the model away from its intended function.

ATLAS gives prompt injection a dedicated technical identifier. OWASP Top 10 for LLMs and GenAI 2025 reinforces the same problem space through **LLM01:2025 Prompt Injection** and **LLM05:2025 Improper Output Handling**. Once an application connects the model to enterprise repositories or downstream functions, prompt injection can become the entry condition for broader abuse, including `AML.T0036 Data from Information Repositories` and, in agentic systems, `AML.T0053 AI Agent Tool Invocation`.

Assessment: Prompt injection is better understood as a cross-boundary control failure than as a single bug class. By 2025-2026 it had moved from a design concern to a routine red-team and production-risk consideration wherever models are connected to retrieval systems, tools, or external actions.

6.3 AI Services, Model APIs, and Covert Relay Potential

AML.T0040 — AI Model Inference API Access

Historical status through April 2026: CONFIRMED as a legitimate and dual-use access path

Modern AI-enabled applications normalize traffic to external inference APIs. That access model creates several technical consequences for defenders: exposed provider keys become privileged secrets, model-access telemetry becomes part of the security perimeter, and sanctioned model endpoints become potential cover traffic if not governed tightly.

AML.T0013 / AML.T0014 / AML.T0069 — Discover AI Model Ontology, Discover AI Model Family, Discover LLM System Information

Historical status through April 2026: RESEARCH / PLAUSIBLE
These ATLAS techniques describe the information-gathering phase that supports jailbreak development, system prompt extraction, and model-specific abuse. By the cutoff, these were already relevant as defensive design concerns even where repeated named-actor public cases were limited.

AML.T0024 — Exfiltration via AI Inference API

Historical status through April 2026: CONFIRMED AS A MATERIAL RISK
As enterprise systems send sensitive prompts and retrieved context to external model providers, the inference path itself becomes a potential data-exposure channel. Public reporting through 2026 shows this as a meaningful enterprise risk, even where named actor attribution remains limited.

AML.T0096 — AI Service API

Historical status through April 2026: CONFIRMED
ATLAS recognizes AI service APIs as a potential communication channel. By late 2025, public reporting confirmed operational use of a commercial AI API as a relay path.

Assessment: AI API traffic is not inherently malicious. The security problem arises when organizations normalize it without token governance, egress policy, and behavioral monitoring.

---

7. Adversary Use of Agentic AI

> ***Historical note:*** *As of April 12, 2026, agentic AI misuse is no longer purely hypothetical in the public record. The strongest cases remain provider-sourced, especially Anthropic's August and November 2025*

> *disclosures, so they require caution. Even so, the risk introduced when LLMs receive memory, tools, and delegated authority is now supported by public casework rather than forecast alone.*

7.1 Excessive Agency as the Core Architectural Risk

OWASP **LLM06:2025 Excessive Agency** is the clearest modern framing for agentic AI abuse. The root problem is not that a model can generate text; it is that the surrounding application grants the model the ability to act. OWASP identifies three recurring causes:

- excessive functionality
- excessive permissions
- excessive autonomy

This is the condition that turns a prompt-injection flaw, hallucinated instruction, or ambiguous output into a real-world security event. The 2025 public record shows that once models are granted meaningful authority, the difference between "assistant" and "operator" becomes operational rather than semantic.

7.2 Tool-Calling Risks Mapped to ATLAS

- `AML.T0053 AI Agent Tool Invocation` — adversaries induce an agent to call downstream tools, APIs, or services.
- `AML.T0085.001 AI Agent Tools` — adversaries enumerate or abuse the tool surface exposed to the agent.
- `AML.T0080 AI Agent Context Poisoning` — adversaries manipulate persistent context or memory to alter future behavior.
- `AML.T0084 Discover AI Agent Configuration` — adversaries discover prompts, memory, tool definitions, identities, or connection details.
- `AML.T0083 Credentials from AI Agent Configuration` — adversaries extract API keys, tokens, or connection strings from agent configuration.
- `AML.T0081 Modify AI Agent Configuration` — adversaries alter configuration to persist malicious behavior or weaken controls.
- `AML.T0086 Exfiltration via AI Agent Tool Invocation` — write-enabled tools become exfiltration channels.
- `AML.T0099 AI Agent Tool Data Poisoning` — adversaries place malicious content where the agent's tools will retrieve it.

- **`AML.T0034.002 Agentic Resource Consumption`** — adversaries induce expensive tool fan-out, excessive calls, or budget exhaustion.
- **`AML.T0108 AI Agent`** and **`AML.T0096 AI Service API`** — current ATLAS taxonomy also treats agent frameworks and AI service APIs as possible abuse paths for relay, tasking, or covert control.

7.3 Security Implication

The principal security equation for agentic systems is:

model weakness x permissions x automation x reachable systems = operational risk

Prompt injection is often only the trigger. The material damage comes from what the agent is allowed to do after it is influenced. This is why agentic security deserves separate treatment rather than being folded into generic prompt-injection discussion. The 2025 casework indicates that the decisive variables are not model eloquence or benchmark scores, but reachable tools, token scope, memory persistence, and whether humans remain in the approval path.

Current ATLAS mitigations map directly to this problem set: `AML.M0026 Privileged AI Agent Permissions Configuration`, `AML.M0027 Single-User AI Agent Permissions Configuration`, `AML.M0028 AI Agent Tools Permissions Configuration`, `AML.M0029 Human-In-the-Loop for AI Agent Actions`, and `AML.M0030 Restrict AI Agent Tool Invocation on Untrusted Data`.

---

8. Statistics and Measurable Trends

> *No global authority publishes a complete year-by-year census of "AI-enabled attacks." The comparison below therefore uses a fixed coding scheme applied to this report's evidence base rather than claiming exhaustive world totals. Numbers increase across years in part because reporting accumulates over time — the table tracks the visibility of documented activity within this corpus, not the volume of global attacks.*

8.1 Year-over-Year Comparison, 2019-2025

Year	Official/provider disclosures in scope*	Documented attack surface classes**	AI-improved TTP families***	Dominant shift
2019	0	1	1	Synthetic voice enters BEC-style fraud
2020	0	1	1	Deep-voice fraud scales dramatically in dollar impact
2021	0	2	2	LLM-phishing capability becomes visible in research
2022	1	2	2	Mass-market LLM access lowers the barrier to phishing and fraud scripting
2023	1	3	6	State-linked experimentation and AI-assisted identity fraud become clearer
2024	8	5	9	Provider telemetry, prompt injection, and multi-person deepfake fraud expand the picture
2025	10	8	12	Runtime AI malware, AI-service misuse, and agentic offensive support enter the public record

* **Official/provider disclosures in scope** = government, platform-provider, or incident-response disclosures directly used in this report and mapped to the activity year they illuminate.
* *Attack surface classes in this coding scheme = synthetic audio, synthetic video, hosted LLM platforms, AI-assisted identity fraud, AI-enabled enterprise applications, AI-service/API channel, agentic/coding assistants, AI-integrated malware or on-host AI tooling, and AI middleware/supply chain.*
* *AI-improved TTP families** in this coding scheme = impersonation fraud, phishing/lure generation, reconnaissance, translation/localization, persona fabrication, coding or malware development, vulnerability research, prompt injection/jailbreak, post-compromise discovery/collection support, runtime AI malware, AI-service relay/C2, agentic intrusion or extortion orchestration, and AI-infrastructure supply-chain targeting.

8.2 2026 YTD Snapshot

By **April 12, 2026**, the public record is too incomplete for a full-year comparison, but the trajectory is clear:

- **Official/provider disclosures in scope:** `5`
- **Attack surface classes visible in the coding scheme:** `9 of 9`
- **AI-improved TTP families visible in the coding scheme:** `13 of 13`

The 2026 year-to-date evidence does **not** show a clean break to generalized autonomous intrusion. It does show consolidation in three areas:

- AI-assisted phishing infrastructure is becoming more automated and timing-aware, as shown by Microsoft's April 6, 2026 device-code-phishing case.
- Threat reporting now treats AI as standard tradecraft support across reconnaissance, phishing, identity abuse, and post-compromise analysis.
- AI infrastructure itself has become part of the target set, as shown by the March 2026 LiteLLM compromise.

8.3 Hard Numbers

- **March 2019 voice-cloning case:** EUR220,000 loss.
- **January 2020 UAE deep-voice case:** approximately USD35 million loss.
- **February 2024 Hong Kong reported deepfake case:** HKD200 million loss.
- **IBM X-Force benchmark (2023):** roughly **5 minutes** to generate a phishing email from five prompts versus roughly **16 hours** for a human red-team workflow (controlled vendor experiment under defined conditions; operational time deltas will vary by context).
- **UIUC one-day exploitation benchmark (April 2024):** GPT-4 exploited **87%** of the 15 one-day vulnerabilities when given the CVE description, and **7%** without it.
- **Google GTIG (January 2025):** APT actors from **more than 20 countries** were observed using Gemini.
- **Anthropic (August 2025):** at least **17 organizations** targeted in an extortion case, with some ransom demands exceeding **$500,000**.
- **Anthropic (November 2025):** roughly **30 targets** in a reported espionage campaign with **80-90%** of campaign actions attributed to AI by Anthropic's own assessment.
- **OpenAI (October 7, 2025):** over **40 networks** disrupted and reported since public threat reporting began in February 2024.

- **FBI IC3 2025 annual report, available by April 2026: 22,364 AI-related complaints** and **$893,346,472** in AI-related losses.

8.4 Comparative Interpretation

- **2019-2020:** High-impact fraud appears first; visibility is low and evidence is mostly secondary.
- **2021-2022:** Capability democratization becomes the main story. The important change is access, not novel offensive technique.
- **2023-2024:** Provider telemetry and application-security research expand the evidence base. Threat actors are clearly using AI, but mostly for support tasks.
- **2025:** The public record diversifies sharply. Runtime AI malware, AI-service abuse, and agentic misuse move from forecast to documented casework.
- **2026 YTD:** The AI threat problem broadens again, from attacker use of models to direct targeting of AI middleware, identity flows, and trusted AI-connected infrastructure.

---

9. Reality vs. Hype

9.1 What AI Is Genuinely Changing

1. **Social engineering quality.** AI reduces grammar, translation, and tone defects that historically exposed phishing and fraud.
2. **Operational tempo.** AI compresses drafting, summarization, translation, and scripting time.
3. **Impersonation realism.** Voice cloning and deepfake video weaken controls that treat familiar voice or appearance as reliable identity proof.
4. **Operational integration.** By 2025, the public record includes malware that queries or leverages models during execution, and agentic systems that support intrusion and extortion workflows.
5. **Attack surface expansion.** AI-connected applications introduce prompt injection, unsafe output handling, unsafe tool invocation, token theft, and AI-adjacent supply chain exposure as material security concerns.

9.2 What the Evidence Does Not Support Through April 2026

1. **Fully autonomous advanced intrusion at operational scale.** Even by April 2026, the public record does not support that claim with strong, independently corroborated evidence.
2. **Major ransomware programs rebuilding core encryption operations around AI.** Public evidence still points more strongly to AI support in development, targeting, or low-skill enablement than to re-architected flagship ransomware operations.
3. **A wholesale replacement of human operators.** The strongest cases still show humans selecting targets, setting objectives, approving key actions, or correcting model errors.
4. **A clean break into an entirely separate AI warfighting category.** The record now includes some genuinely novel operational patterns, but the dominant trend is still modification and acceleration of known tradecraft.

9.3 Analytical Verdict

Through April 2026, AI has produced a non-linear capability increase in selected parts of the attack lifecycle and a meaningful expansion of the enterprise attack surface, but not a documented replacement of end-to-end human intrusion tradecraft.

The most important distinction is this:

- **AI as an attacker productivity amplifier:** confirmed
- **AI as a fraud realism amplifier:** confirmed
- **AI as an AI-application exploitation vector:** confirmed
- **AI as a substantial offensive operator in selected public cases:** confirmed, but unevenly corroborated
- **AI as a fully autonomous offensive operator at scale:** not confirmed by the cutoff

---

10. Actor Segmentation

10.1 Financially Motivated Fraud Operators

Adoption level: HIGH
Why: Their mission aligns directly with current model strengths: persuasion, impersonation, multilingual interaction, and low-cost content generation.

Assessment: This remains the most operationally mature AI-enabled actor class in the public record through April 2026.

10.2 State-Linked Actors

Adoption level: MEDIUM to HIGH
Why: Provider-backed reporting now confirms use across reconnaissance, translation, phishing, vulnerability research, malware support, post-compromise analysis, and in some 2025 cases higher-autonomy operational support.
Assessment: Public evidence is still uneven by country and provider visibility. Iran, China, and DPRK appear most frequently in the public record, but the distribution is partly a function of what the major platforms can observe.

10.3 Ransomware Ecosystem

Adoption level: LOW to MEDIUM
Why: Public discussion remains louder than the evidence, but 2025 casework shows AI-assisted ransomware development and low-skill malware commercialization.
Assessment: The strongest operational relevance remains indirect or supportive: phishing, scripting, targeting, triage, and development assistance rather than AI-operated flagship encryption workflows.

10.4 Influence and Information Operations

Adoption level: LOW to MEDIUM
Why: AI clearly lowers content-production costs and translation friction, and provider reporting confirms recurring misuse in IO workflows.
Assessment: The strongest defensible claim remains scale and efficiency increase. The evidence base for decisive real-world audience impact remains weaker than for fraud and phishing.

10.5 Hacktivists and Low-Skill Opportunists

Adoption level: LOW to MEDIUM
Why: LLMs lower the expertise threshold for phishing, messaging, and simple scripting.
Assessment: The main effect is access uplift from a low baseline.

---

11. Supply Chain & Infrastructure

> ***Defensive framing note:*** *The historical record now runs through April 12, 2026, but this section still uses current ATLAS and OWASP 2025 language to organize defensive risk across the modern AI stack.*

AI stack layer	Principal risks	Representative ATLAS mappings	Relevant OWASP 2025 lens	Historical signal through April 2026	Priority controls
Model	Inference API abuse, model fingerprinting, system prompt leakage, provider-key exposure, model-specific jailbreak discovery	`AML.T0040`, `AML.T0013`, `AML.T0014`, `AML.T0069`, `AML.T0024`	`LLM02 Sensitive Information Disclosure`, `LLM03 Supply Chain`, `LLM04 Data and Model Poisoning`	Public research, provider telemetry, and repeated platform-abuse cases are now visible; model access is clearly a governed security boundary	Model inventory, API gatewaying, scoped credentials, rate limits, telemetry, provider access review
App	Prompt injection, improper output handling, unsafe session/state handling, covert use of sanctioned AI APIs	`AML.T0051`, `AML.T0096`	`LLM01 Prompt Injection`, `LLM05 Improper Output Handling`, `LLM07 System Prompt Leakage`	Prompt injection was clearly visible by 2024; by 2025-2026 AI-service relay abuse and unsafe application mediation are confirmed concerns	Strict input separation, output validation, egress allowlisting, session/state review, policy logging

AI stack layer	Principal risks	Representative ATLAS mappings	Relevant OWASP 2025 lens	Historical signal through April 2026	Priority controls
Data	Poisoned RAG content, over-broad repository access, sensitive data disclosure, vector or embedding weaknesses	`AML.T0036`, `AML.T0099`	`LLM02 Sensitive Information Disclosure`, `LLM04 Data and Model Poisoning`, `LLM08 Vector and Embedding Weaknesses`	Poisoned-content and retrieval abuse are established design risks; later casework increases their operational importance	Provenance controls, ACL-preserving retrieval, chunk tagging, DLP, canary content, repository segmentation
Tools	Excessive agency, tool misuse, agent configuration discovery, credential theft, exfiltration through write-enabled tools, budget exhaustion	`AML.T0053`, `AML.T0080`, `AML.T0081`, `AML.T0083`, `AML.T0084`, `AML.T0086`, `AML.T0034.002`	`LLM06 Excessive Agency`, `LLM10 Unbounded Consumption`, `LLM03 Supply Chain`	Tool-calling risk is now supported by public provider casework, not just design analysis	Least privilege, single-user identities, human approval, tool allowlists, rate limiting, continuous AI red teaming

---

12. Technical Evolution (Last 24 Months)

12.1 2024 — Provider Telemetry and Application-Layer Risk

The 2024 record established two durable facts. First, named state-affiliated actors were already using LLMs in support roles. Second, AI-enabled applications themselves had become a viable attack surface through prompt injection, guardrail bypass, and unsafe tool integration. This is the year in which AI security ceased to be only a model-governance issue and became an enterprise application-security issue.

12.2 2025 — Operational Inflection Point

The 2025 record broadened from "AI helps attackers work faster" to "AI is now present inside parts of live operations." Public reporting now included runtime AI malware, AI-assisted self-modifying code, AI-service relay misuse, and provider-reported agentic support for extortion and espionage. The practical consequence was not universal autonomy, but broader AI presence across delivery, execution, post-compromise analysis, and exfiltration support.

12.3 Early 2026 — AI as Tradecraft and AI as Attack Surface

By early 2026, the emerging pattern was consolidation rather than novelty for novelty's sake. Microsoft's March and April 2026 reporting showed AI strengthening reconnaissance, phishing, backend automation, and post-compromise processing. At the same time, the LiteLLM compromise showed that AI middleware and orchestration layers had become targets in their own right. The threat model now has two parallel branches: **AI used by attackers**, and **AI infrastructure attacked by attackers**.

---

13. Forecast (Post-April 2026)

> ***This section projects forward from the April 12, 2026 evidence baseline.***

13.1 Most Likely Developments Over the Next 12 Months

Projected Threat 1 [Almost certain] — **AI-assisted impersonation fraud, phishing, and identity abuse will continue to scale faster than high-end AI-assisted intrusion.**
Rationale: the return on investment is immediate, the tooling is accessible, and the control failures are still widespread.

Projected Threat 2 [Highly likely] — **Prompt injection and excessive agency will become routine adversary and red-team tradecraft against enterprise copilots, agents, and RAG workflows.**
Rationale: these paths exploit trust boundaries and connector permissions rather than memory corruption, making them structurally attractive.

Projected Threat 3 [Highly likely] — **AI API token theft, connector abuse, and AI-adjacent supply chain compromise will grow as organizations expand model access.**

Rationale: provider keys, orchestration proxies, agent configs, and retrieval connectors increasingly function as privileged credentials and trust anchors.

Projected Threat 4 [Likely] — **Semi-autonomous operator loops will become more common for bounded tasks such as target research, exploit triage, phishing generation, malware modification, and stolen-data review.**
Rationale: the current evidence already shows value in narrow loops even where full autonomy remains unreliable.

Projected Threat 5 [Likely] — **Trusted cloud and AI services will be used more aggressively as blend-in infrastructure for phishing, staging, redirect chains, and low-volume control channels.**
Rationale: defenders still over-trust sanctioned cloud and AI traffic compared with traditional attacker infrastructure.

Projected Threat 6 [Likely] — **AI-enhanced OAuth and identity-flow abuse will increase.**
Rationale: device-code phishing, workforce fraud, and synthetic-identity operations align directly with AI's strengths in personalization, timing, and role mimicry.

13.2 What Remains Less Likely in the Near Term

Projected Threat 7 [Unlikely] — **Fully autonomous, end-to-end advanced intrusion at operational scale.**
Rationale: stealth, target-specific judgment, deconfliction, error recovery, and operational security still benefit heavily from skilled humans.

Projected Threat 8 [Unlikely] — **Major ransomware programs materially re-architecting their core encryption and deployment workflows around AI.**
Rationale: mature crews still optimize for reliability, tested playbooks, and deterministic payload behavior.

Projected Threat 9 [Realistic possibility] — **A sharper jump in public agentic casework from a second provider or government source.**
Rationale: the capability direction is plausible, but broader corroboration has not yet caught up with the most aggressive 2025 provider disclosures.

---

14. Final Conclusions

1. Through April 2026, the most important AI offense story is still not general-purpose autonomous hacking. It is better fraud, better phishing, faster attacker support functions, and broader exposure of

the enterprise AI stack.

2. 2025 was the public inflection point. That is when the record moved beyond support tasks and into LLM-integrated malware, AI-service misuse, and public provider disclosures of agentic offensive support.

3. The most defensible AI-specific attack surface is the enterprise AI stack itself. Prompt injection, unsafe output handling, excessive agency, unsafe connector design, token exposure, and AI-adjacent supply chain compromise are now first-order risks.

4. Public reporting still shows humans retaining control over objectives, targeting, or key approvals. Even the strongest 2025 public claims do not justify calling fully autonomous intrusion a mature, generalized operational reality.

5. Fraud controls are cyber controls, and AI controls are identity controls. Organizations that still trust voice, video, polished language, or AI-connected workflows without strong authorization boundaries are exposed.

6. The next threat transition is more likely to come from insecure integration and excessive agency than from model autonomy alone. The decisive issue is what the model can access, invoke, retrieve, send, or exfiltrate on behalf of a user or agent.

---

15. Defender Recommendations

Immediate Technical Controls

1. **Adopt an internal LLM content security policy pattern.** Treat AI applications like browsers with a strict allowlist: approved data sources, approved tools, approved outbound domains, maximum privilege level, and explicit approval requirements for side-effecting actions. This is an architectural pattern, not a formal industry standard.

2. **Broker all enterprise model access through a controlled gateway.** Do not let endpoints, scripts, and individual applications call external model APIs directly with unmanaged long-lived tokens.

3. **Enforce egress controls for AI APIs.** Allowlist approved AI provider domains and block outbound AI API traffic from systems that should not be invoking models. Treat unexpected traffic to model endpoints as a detection event.

4. **Rotate and scope AI API tokens aggressively.** Use short-lived credentials where possible, workload identity where available, separate tokens by environment and application, and revoke on role change or suspected exposure. Apply the same control standard to AI middleware secrets, package-publish tokens, and connector credentials.

5. **Separate instructions from untrusted content.** Delimit retrieved documents, emails, tickets, webpages, and attachments so the model can distinguish data from control text. Do not concatenate raw untrusted content into high-privilege instruction context.

6. **Enforce least privilege for agents and tools.** For agentic systems, map permissions explicitly to the ATLAS control model: `AML.M0026 Privileged AI Agent Permissions Configuration`, `AML.M0027 Single-User AI Agent Permissions Configuration`, and `AML.M0028 AI Agent Tools Permissions Configuration`.

7. **Require human approval for high-impact agent actions.** Sending email, executing code, modifying repositories, deleting data, or initiating financial workflows should require policy checks and human confirmation. This aligns directly to `AML.M0029 Human-In-the-Loop for AI Agent Actions`.

8. **Restrict tool invocation on untrusted data.** If an agent is processing external email, webpages, tickets, or uploaded documents, disable or heavily constrain automatic tool use. This aligns to `AML.M0030 Restrict AI Agent Tool Invocation on Untrusted Data`.

9. **Never execute model output directly.** All code, shell commands, SQL, browser actions, and infrastructure changes generated by a model should pass through validation and least-privilege execution boundaries.

10. **Log the full decision chain.** Retain prompt metadata, retrieved context references, tool invocations, outbound connectors, policy decisions, and model outputs in centralized telemetry with appropriate privacy controls.

11. **Apply DLP and secret scanning to both prompts and outputs.** Sensitive data loss can occur in either direction: user-to-model or model-to-user.

12. **Harden approval workflows against synthetic impersonation.** Payment releases, privileged account resets, and executive requests should require out-of-band verification and cryptographic or device-bound factors where possible.

Continuous Assurance

13. **Run AI red teaming as a continuous process, not a one-time test.** Align scenarios to OWASP 2025 risk areas such as `LLM01 Prompt Injection`, `LLM05 Improper Output Handling`, `LLM06 Excessive Agency`, and `LLM10 Unbounded Consumption`, and to ATLAS techniques such as `AML.T0051`, `AML.T0053`, `AML.T0080`, `AML.T0086`, `AML.T0096`, and `AML.T0034.002`.
14. **Re-test on every material architecture change.** Trigger AI red teaming when the model changes, the system prompt changes, a new connector or tool is added, an agent gets new permissions, or a retrieval source is widened.
15. **Red-team prompt injection and tool abuse together.** Testing prompt injection in isolation is insufficient for agentic systems. The meaningful question is whether an attacker can convert prompt influence into tool invocation, data access, or destructive action.
16. **Reduce connector blast radius.** Limit model-connected access to email, drives, source code, ticketing systems, CRMs, and browsers to the minimum data scope required for the use case.
17. **Instrument anomaly detection for AI usage.** Useful signals include unexpected model traffic, unusual token geography, abnormal prompt volume, sudden connector fan-out, unexpected tool invocation, and retrieval of sensitive repositories inconsistent with user role.
18. **Build incident response playbooks for AI-enabled abuse.** Include prompt-injection containment, token revocation, retrieved-data exposure analysis, unsafe-output forensics, agent configuration review, provider engagement procedures, and AI middleware or connector compromise response.

Strategic Direction

19. **Design AI systems for constrained agency by default.** Give models bounded tools, bounded data, bounded time, and bounded authority.
20. **Shift from trust-in-content to trust-in-control.** The model can improve content quality for both defenders and attackers. Trust decisions must rely on identity, authorization, and policy enforcement, not on how convincing a message or meeting appears.

---

16. Key Selected Sources

Quality labels: **PRIMARY** = government, court-derived, or direct company / platform disclosure. **SECONDARY** = academic preprint, vendor experiment, or media reporting with primary-document basis.

Primary sources

- MITRE ATLAS, *ATLAS official knowledge base* and official data repository — *PRIMARY framework source*. Authoritative source for `AML` tactics, techniques, and mitigations used in this revision.
- NCSC, *The near-term impact of AI on the cyber threat* — January 24, 2024. *PRIMARY.* Baseline government assessment and probability-language model.
- OpenAI, *Disrupting malicious uses of AI by state-affiliated threat actors* — February 14, 2024. *PRIMARY.* Core source for named state-affiliated actor use of LLMs.
- OpenAI, *Disrupting deceptive uses of AI by covert influence operations* — May 30, 2024. *PRIMARY.* Useful for AI-enabled influence operations and scale-vs-impact analysis.
- Microsoft Security Blog, *How Microsoft discovers and mitigates evolving attacks against AI guardrails* — April 11, 2024. *PRIMARY.* Direct and indirect prompt injection; multi-turn jailbreaks; defensive controls.
- FinCEN, *Alert on Fraud Schemes Involving Deepfake Media Targeting Financial Institutions* — November 13, 2024. *PRIMARY.* U.S. regulatory warning on deepfake-enabled fraud.
- Google GTIG, *Adversarial Misuse of Generative AI* — January 29, 2025. *PRIMARY.* Broad provider-backed assessment of APT and IO actor misuse of Gemini.
- OpenAI, *Disrupting malicious uses of AI* — February 21, 2025. *PRIMARY.* Continuing public casework on scams, covert influence, and cyber misuse.
- FBI IC3, *Impersonation of Senior U.S. Officials and Their Contacts* — May 15, 2025. *PRIMARY.* Official warning on impersonation campaigns affecting senior U.S. officials and their contacts.
- OpenAI, *Disrupting Malicious Uses of AI: June 2025* — June 5, 2025. *PRIMARY.* Multi-network casework including cyber, scam, and deceptive employment activity.
- Anthropic, *Detecting and countering misuse: August 2025* — August 27, 2025. *PRIMARY.* Key source for Claude Code misuse in extortion and related abuse trends.
- OpenAI, *Disrupting malicious uses of AI: October 2025* — October 7, 2025. *PRIMARY.* Reports more than 40 disrupted malicious networks since threat reporting began.
- Microsoft Security Blog, *SesameOp: Novel backdoor uses OpenAI Assistants API for command and control* — November 3, 2025. *PRIMARY.* High-signal case of AI-service API abuse as an operational channel.
- Google GTIG, *Threat actor usage of AI tools* — November 5, 2025. *PRIMARY.* Key source for PROMPTSTEAL, PROMPTFLUX, QUIETVAULT, and broader AI-enabled malware observations.

- Anthropic, *Disrupting the first reported AI-orchestrated cyber espionage campaign* — November 13, 2025. *PRIMARY.* Provider disclosure on high-autonomy agentic espionage use.
- FBI IC3, *Senior U.S. Officials Impersonated in Ongoing Malicious Messaging Campaign* — December 19, 2025. *PRIMARY.* AI-generated voice impersonation warning tied to sustained targeting of senior officials.
- OpenAI, *Disrupting malicious uses of AI* — February 25, 2026. *PRIMARY.* 2026 update on multi-model and cross-platform threat actor misuse.
- Microsoft Security Blog, *AI as tradecraft: How threat actors operationalize AI* — March 6, 2026. *PRIMARY.* Current Microsoft view on how AI is operationalized across the attack lifecycle.
- Wiz Research, *Three's a Crowd: TeamPCP trojanizes LiteLLM* — March 24, 2026. *PRIMARY vendor incident report.* Core source for the LiteLLM compromise and AI middleware supply-chain risk.
- Microsoft Security Blog, *AI-enabled device code phishing campaign* — April 6, 2026. *PRIMARY.* Current case study showing AI-enhanced phishing automation and post-compromise enrichment.
- FBI IC3, *2025 Internet Crime Report* — available by April 2026. *PRIMARY.* First IC3 annual report to publish an AI-related descriptor and associated complaint/loss totals.
- U.S. Treasury / OFAC, *Guidance on the Democratic People's Republic of Korea Information Technology Workers* — May 16, 2022. *PRIMARY.* Useful context for identity fraud and remote-worker tradecraft.

Secondary, research, and defensive framework sources

- HKCERT, *Phishing Alert - Public should be vigilant against fraudulent video conference scam using AI Deepfake technology* — February 7, 2024. *SECONDARY official bulletin.* Hong Kong deepfake video-conference fraud summary based on police and media reporting rather than a direct victim disclosure. *(Editorial note: The URL slug references an unrelated Instagram 2FA phishing path; the landing-page title and body text correspond to the cited deepfake bulletin. The URL is preserved for traceability pending identification of a canonical permalink.)*
- OWASP, *LLM01:2025 Prompt Injection* — *SECONDARY framework reference.* Direct source for the prompt-injection defensive framing used in this revision.
- OWASP, *LLM05:2025 Improper Output Handling* — *SECONDARY framework reference.* Direct source for the output-handling risk model used in this revision.
- OWASP, *LLM06:2025 Excessive Agency* — *SECONDARY framework reference.* Core source for the dedicated agentic-AI risk section.

- OWASP, *LLM10:2025 Unbounded Consumption* — *SECONDARY framework reference.* Direct source for the resource-consumption and denial-of-wallet framing used in this revision.
- OWASP, *GenAI Red Teaming Initiative* — *SECONDARY framework reference.* Current OWASP initiative used to support the recommendation that AI red teaming be treated as a continuous process.
- Singapore government GPT-3 phishing benchmark — August 2021. *RESEARCH.* Singapore government researchers demonstrated that GPT-3-generated spear-phishing emails could match or outperform human-crafted lures in controlled conditions. *(Canonical source URL to be confirmed before publication; referenced in Section 4 timeline under August 2021.)*
- Richard Fang et al., *LLM Agents can Autonomously Exploit One-day Vulnerabilities* — submitted April 11, 2024; revised April 17, 2024. *RESEARCH / SECONDARY.* Key research signal for one-day exploitation capability.
- Trend Micro, *Hype vs. Reality: AI in the Cybercriminal Underground* — August 15, 2023. *SECONDARY.* Strong corrective on WormGPT / FraudGPT claims.
- IBM X-Force, *AI vs. human deceit: Unravelling the new age of phishing tactics* — 2023. *SECONDARY vendor experiment.* Useful for productivity delta and near-parity social-engineering quality.
- Forbes, *Fraudsters Cloned Company Director's Voice In $35 Million Heist, Police Find* — October 14, 2021. *SECONDARY with court-document basis.* Best accessible source for the 2020 UAE case.
- KnowBe4 summary of Wall Street Journal reporting, *AI Used For Social Engineering. Fraudsters Mimic CEO's Voice in Unusual Cybercrime Case* — August 30, 2019. *SECONDARY.* Best accessible source for the 2019 UK voice-fraud case.

Evidence cutoff: April 12, 2026. Section 8 compares full-year 2019-2025 activity; 2026 is treated separately as a partial-year update. Section 13 is a forward forecast from this baseline rather than historical event reporting.

Classification: Open source / Unclassified.

For corrections, additional sourcing, or technical questions: Medium @1200km

↑ Back to top